

SEGURANÇA EM REDES IoT: ATAQUES POR CREDENCIAIS PADRÃO E O CASO MIRAI

Alunos: Henrique Pereira Chagas Corrêa e Pedro Guilherme

1. Introdução

A Internet das Coisas (IoT) reúne dispositivos conectados à rede que coletam, trocam e processam dados. Entre os exemplos mais comuns estão câmeras de segurança, roteadores domésticos, impressoras, lâmpadas inteligentes, sensores industriais, assistentes virtuais e equipamentos utilizados na área da saúde. Esses dispositivos facilitam tarefas cotidianas, permitem automação e contribuem para o monitoramento de ambientes residenciais e corporativos.

Apesar das vantagens, a expansão da IoT também aumentou os riscos de segurança. Muitos equipamentos são desenvolvidos com foco em baixo custo, facilidade de instalação e consumo reduzido de energia. Em alguns casos, aspectos como proteção de dados, autenticação de usuários e atualização de segurança recebem menor atenção durante o processo de fabricação.

Um dos problemas mais frequentes em redes IoT é o uso de credenciais fracas, padrão ou fixas no firmware. Isso acontece quando o fabricante entrega o dispositivo com usuário e senha genéricos, como “admin/admin”, ou quando o consumidor não altera essas informações após a instalação. Há ainda situações em que a senha não pode ser modificada, pois está gravada diretamente no software do equipamento.

Este relatório tem como objetivo analisar esse problema, explicar como ele pode ser explorado em um ataque real e apresentar medidas que podem ser utilizadas para reduzir os riscos. O caso estudado é o botnet Mirai, um dos incidentes mais conhecidos envolvendo dispositivos IoT e senhas padrão.

2. O problema: credenciais fracas em dispositivos IoT

Dispositivos IoT costumam possuir interfaces de administração acessíveis pela rede. Essas interfaces podem ser páginas web locais, aplicativos móveis, serviços em nuvem ou protocolos

de acesso remoto, como Telnet e SSH. Por meio delas, é possível configurar o equipamento, atualizar o firmware, visualizar imagens de câmeras ou controlar funções do dispositivo.

Quando o acesso administrativo é protegido por uma senha padrão, um atacante pode tentar acessá-lo remotamente. O problema se torna mais grave porque muitos usuários não alteram a senha inicial, especialmente em equipamentos instalados por empresas de internet, câmeras de vigilância ou dispositivos comprados para uso doméstico.

A OWASP classifica essa falha como “Weak, Guessable, or Hardcoded Passwords”, ou seja, senhas fracas, adivinháveis ou fixas no código. De acordo com a organização, esse risco inclui credenciais facilmente descobertas por força bruta, senhas públicas ou imutáveis e portas dos fundos no firmware que concedem acesso não autorizado.

Esse problema é especialmente preocupante porque muitos dispositivos IoT permanecem ligados durante todo o dia e podem ficar expostos diretamente à Internet. Uma câmera de segurança, por exemplo, pode ser acessada remotamente por meio de redirecionamento de portas no roteador ou por um serviço de acesso externo. Se as credenciais forem fracas ou conhecidas, o atacante pode assumir o controle sem precisar estar fisicamente próximo do equipamento.

3. Como ocorre um ataque: o caso Mirai

O Mirai foi um malware que surgiu em 2016 e se espalhou principalmente entre dispositivos IoT mal protegidos, como câmeras IP, roteadores e gravadores digitais de vídeo, conhecidos como DVRs. Seu objetivo não era necessariamente roubar informações armazenadas nos aparelhos, mas transformá-los em parte de uma rede de dispositivos infectados, chamada botnet.

Uma botnet é um conjunto de equipamentos comprometidos que recebe comandos de um atacante. No caso do Mirai, os dispositivos infectados foram utilizados para realizar ataques de negação de serviço distribuída, conhecidos como DDoS, sigla em inglês para Distributed Denial of Service.

Em um ataque DDoS, milhares de máquinas enviam tráfego simultaneamente para um alvo. Isso sobrecarrega servidores, links de rede ou serviços online, impedindo que usuários

legítimos consigam acessá-los. Diferentemente de um ataque comum, que parte de um único computador, o DDoS utiliza uma grande quantidade de dispositivos distribuídos em diferentes redes e regiões.

3.1 Etapas do ataque

O funcionamento do Mirai pode ser resumido nas seguintes etapas:

- Varredura da Internet: o malware envia pacotes TCP SYN para endereços IP aleatórios, procurando dispositivos com as portas Telnet 23 e 2323 abertas. O Telnet é um protocolo antigo de acesso remoto que, em sua forma tradicional, não oferece criptografia nem proteção adequada das credenciais.
- Teste de credenciais: ao encontrar um dispositivo possível, o Mirai tenta realizar login utilizando uma lista pré-configurada de combinações de usuário e senha. A análise acadêmica do USENIX indica que o malware utilizava dez pares de credenciais escolhidos aleatoriamente entre 62 combinações conhecidas.
- Infecção do dispositivo: se uma das tentativas for bem-sucedida, o malware registra o endereço IP e as credenciais do aparelho em um servidor controlado pelos atacantes. Em seguida, instala o código malicioso no dispositivo.
- Formação da botnet: o equipamento infectado passa a fazer parte da rede controlada pelos criminosos. Ele pode receber ordens para participar de ataques DDoS contra sites, provedores de DNS ou outras infraestruturas online.
- Ataque ao alvo: quando o atacante deseja interromper um serviço, envia um comando para que milhares de dispositivos infectados gerem tráfego simultaneamente contra o alvo.

3.2 Impacto do ataque

A pesquisa “Understanding the Mirai Botnet”, apresentada na conferência USENIX Security em 2017, acompanhou a propagação do malware e identificou que ele infectou quase 65 mil dispositivos IoT nas primeiras 20 horas. Antes de atingir uma população estável, o botnet chegou a infectar entre 200 mil e 400 mil dispositivos.

O incidente mais conhecido ocorreu em outubro de 2016, quando dispositivos infectados pelo Mirai foram usados contra a Dyn, empresa que oferece serviços de DNS. Como o DNS é responsável por traduzir nomes de domínios em endereços IP, a interrupção afetou o acesso a diversos serviços populares na Internet.

O caso demonstrou que um ataque não precisa comprometer diretamente um servidor grande ou uma empresa específica. Basta que criminosos consigam controlar um grande número de dispositivos domésticos mal configurados para causar impacto em serviços utilizados por milhões de pessoas.

4. Por que o ataque foi possível

O sucesso do Mirai não dependeu de uma vulnerabilidade extremamente complexa. Pelo contrário, ele explorou falhas básicas de configuração e segurança que continuam presentes em muitos dispositivos.

- Uso de senhas padrão: muitos equipamentos saem de fábrica com usuários e senhas conhecidos, como “admin”, “root”, “123456” ou combinações semelhantes.
- Falta de alteração de senha pelo usuário: parte dos consumidores não sabe que precisa configurar uma senha forte após a instalação.
- Exposição de serviços administrativos: portas como Telnet permanecem habilitadas e acessíveis pela Internet, mesmo quando não são necessárias.
- Ausência de bloqueio contra tentativas repetidas: dispositivos que não limitam tentativas de login facilitam ataques de força bruta.
- Firmware desatualizado: muitos equipamentos não recebem atualizações regulares ou exigem procedimentos complicados para atualização.
- Falta de segmentação de rede: dispositivos IoT muitas vezes ficam na mesma rede de computadores pessoais, celulares e sistemas corporativos, permitindo que um equipamento comprometido alcance outros recursos.

A OWASP destaca tanto credenciais fracas quanto serviços de rede inseguros como riscos centrais em IoT. Serviços desnecessários ou mal protegidos, especialmente quando expostos à Internet, podem comprometer a confidencialidade, a integridade e a disponibilidade das informações.

5. Medidas para prevenir o problema

A prevenção desse tipo de ataque exige ações dos fabricantes, dos usuários e das organizações que administram redes. Não basta apenas trocar uma senha: é necessário adotar uma abordagem de segurança desde o projeto do dispositivo até sua operação.

5.1 Medidas para fabricantes

Os fabricantes devem eliminar senhas padrão conhecidas e exigir que o usuário crie uma credencial única durante a primeira configuração. Também é importante impedir o uso de senhas muito simples, como sequências numéricas ou palavras comuns.

Outra medida essencial é desativar protocolos inseguros ou desnecessários, como Telnet, quando alternativas mais seguras estiverem disponíveis. Quando o acesso remoto for necessário, ele deve utilizar criptografia e autenticação adequadas.

O NIST recomenda que dispositivos IoT possuam capacidades básicas de segurança para proteger o próprio equipamento, seus dados e o ecossistema ao qual estão conectados. O documento NISTIR 8259A define uma linha de base de capacidades de cibersegurança que pode orientar fabricantes na criação e integração de novos dispositivos IoT.

- Exigir configuração inicial segura de credenciais.
- Oferecer atualizações de firmware assinadas e verificáveis.
- Permitir que o usuário saiba quais serviços estão ativos no dispositivo.
- Reduzir a quantidade de portas e serviços expostos por padrão.
- Implementar mecanismos de recuperação segura em caso de comprometimento.
- Documentar claramente as configurações de segurança e os riscos de exposição à Internet.

5.2 Medidas para usuários domésticos

Usuários domésticos podem reduzir bastante o risco com configurações simples:

- Alterar imediatamente a senha padrão de roteadores, câmeras e outros dispositivos.
- Criar senhas longas, únicas e difíceis de adivinhar.
- Desativar o acesso remoto quando ele não for necessário.
- Manter o firmware atualizado sempre que o fabricante disponibilizar atualizações.
- Desativar serviços como Telnet, FTP ou UPnP caso não sejam utilizados.

- Evitar expor câmeras e dispositivos diretamente à Internet por meio de redirecionamento de portas.
- Utilizar uma rede Wi-Fi separada para dispositivos IoT, quando o roteador permitir essa configuração.

A criação de uma rede separada é uma das medidas mais eficazes. Assim, mesmo que uma câmera ou lâmpada inteligente seja comprometida, o atacante terá mais dificuldade para alcançar computadores, celulares, arquivos pessoais ou sistemas da empresa.

5.3 Medidas para empresas

Em ambientes corporativos, a segurança deve ser tratada como parte da gestão da rede.

Dispositivos IoT devem ser inventariados, classificados e monitorados, pois muitos deles permanecem conectados por anos sem receber atenção da equipe de TI.

- Segmentação de rede: separar dispositivos IoT em VLANs ou sub-redes específicas, com regras de firewall que limitem a comunicação apenas com os serviços necessários.
- Controle de acesso: utilizar autenticação forte, listas de permissão e restrição de acesso administrativo.
- Monitoramento: acompanhar tráfego incomum, tentativas repetidas de login, conexões para endereços desconhecidos e uso de portas suspeitas.
- Atualização centralizada: manter um inventário de firmware e aplicar correções de segurança de forma planejada.
- Desativação de serviços desnecessários: fechar portas e protocolos que não sejam essenciais à operação do dispositivo.
- Política de compra: priorizar fornecedores que ofereçam atualizações de segurança, suporte técnico e configurações seguras por padrão.

6. Proposta de solução prática

Para uma rede doméstica ou de pequena empresa, uma solução prática seria adotar a seguinte configuração:

- Separar os dispositivos IoT em uma rede exclusiva.
- Alterar todas as senhas padrão e utilizar credenciais diferentes para cada equipamento.

- Desativar o acesso remoto e serviços como Telnet, exceto quando forem realmente necessários.
- Configurar o roteador para bloquear o acesso externo às interfaces administrativas dos dispositivos.
- Atualizar o firmware de todos os equipamentos e ativar atualizações automáticas quando disponíveis.
- Monitorar a rede por meio do roteador ou de uma ferramenta de segurança, observando dispositivos desconhecidos e conexões suspeitas.

Essa combinação reduz tanto a possibilidade de infecção inicial quanto o impacto caso algum dispositivo seja comprometido. Ainda que nenhum sistema seja totalmente seguro, dificultar o acesso remoto e limitar a comunicação entre redes reduz significativamente as chances de um ataque semelhante ao Mirai.

7. Conclusão

O uso de credenciais fracas, padrão ou fixas em dispositivos IoT continua sendo um dos problemas de segurança mais simples e perigosos. O caso do botnet Mirai mostrou que equipamentos comuns, como câmeras e roteadores, podem ser transformados em ferramentas para ataques de grande escala quando não recebem configurações adequadas.

O ataque do Mirai não exigiu técnicas avançadas: o malware procurava dispositivos com portas Telnet abertas e tentava combinações conhecidas de usuário e senha. A partir desse acesso, os equipamentos eram infectados e incorporados a uma botnet capaz de realizar ataques DDoS em larga escala.

Para reduzir esse risco, fabricantes precisam adotar configurações seguras desde a fábrica, usuários devem alterar senhas e desativar acessos desnecessários, e empresas devem segmentar e monitorar suas redes. As recomendações da OWASP e do NIST reforçam que a segurança de IoT deve considerar não apenas o dispositivo isolado, mas também sua rede, seus dados e todo o ecossistema ao qual ele está conectado.

Referências

ANTONAKAKIS, M. et al. Understanding the Mirai Botnet. USENIX Security Symposium, 2017. Disponível em: <https://www.usenix.org/system/files/conference/usenixsecurity17/sec17-antonakakis.pdf>

OWASP. OWASP Internet of Things Top 10 – 2018. Disponível em: <https://wiki.owasp.org/images/1/1c/OWASP-IoT-Top-10-2018-final.pdf>

NIST. IoT Device Cybersecurity Capability Core Baseline (NISTIR 8259A). 2020. Disponível em: <https://nvlpubs.nist.gov/nistpubs/ir/2020/NIST.IR.8259a.pdf>

NIST. Foundational Cybersecurity Activities for IoT Device Manufacturers (NISTIR 8259). 2020. Disponível em: <https://nvlpubs.nist.gov/nistpubs/ir/2020/NIST.IR.8259.pdf>

CLOUDFLARE RESEARCH. Understanding the Mirai Botnet. 2017. Disponível em: <https://research.cloudflare.com/publications/Antonakakis2017/>

EDIMA. Early Detection of IoT Malware Network. arXiv, 2019. Disponível em: <https://arxiv.org/pdf/1906.09715.pdf>